SECURITY REPORT / EMAIL INTELLIGENCE / OSINT

Esposizione di undici indirizzi email

e@x.com, i domini tesla.com, i typo di hotmail e gmail: breach exposure, attribuzione e metodo

3 INDIRIZZI	2 INDIRIZZI	6 INDIRIZZI	
ALTO	**BASSO**	**DISPOSABLE**	**Target** 11 indirizzi su 9 domini **Finestra** 8–9 novembre 2026 **Motore** MailAccess v0.19.3

11 INDIRIZZI ANALIZZATI 9 domini, 3 con esposizione reale	**38** SEGNALAZIONI DI BREACH 3 indirizzi; dataset in parte sovrapposti	**2** LOG DI INFOSTEALER password in chiaro, run tesla.com
6 DOMINI USA-E-GETTA gmial.com, gmial.ru, hotmial.com	**100 · 100 · 100** ESPOSIZIONE MASSIMA tre run saturi su undici	**0 / 11** IDENTITÀ VERIFICATE una sola “conferma”, fonti non indipendenti

In sintesi

1. Tre indirizzi su undici hanno credenziali esposte. e@x.com (22 dataset), elonmusk@tesla.com (5) e elon@tesla.com (11). Gli ultimi due compaiono in **ALIEN TXTBASE**, un log di infostealer del 2025 con password in chiaro.

2. Otto indirizzi non hanno alcuna esposizione. Sei stanno su domini usa-e-getta o typo (cinque su gmial.com, uno su hotmial.com) e chiudono tra 2 e 4 punti. Gli altri due, elon@nasa.com e Elusk@gmial.ru, arrivano a 82 e 81 senza un solo breach: punteggio alto, rischio nullo.

3. Nessuna identità regge. “Elon Musk” compare in cinque indirizzi su undici, attraverso tre meccanismi: keyserver PGP, local part e commit git. L’unica “conferma” del tool poggia su una commit il cui autore ha scritto “Elon Musk” nella configurazione di git: non è una fonte indipendente.

4. Il punteggio non ordina nulla. Tre indirizzi a 100/100 con 22, 5 e 11 fonti di breach, un dominio parcheggiato a 81/100 con zero: il numero non distingue un’esposizione reale da un wordlist. Per prioritizzare servono le fonti di breach e il rischio credenziali.

Documento redatto a partire dall’output testuale del run, senza accesso ai dataset sorgente. Ambito: valutazione difensiva dell’esposizione. Nessuna verifica offensiva, nessun tentativo di accesso agli account elencati.

CONTENUTI

1. Sintesi esecutiva 2
2. Avvertenza metodologica 2
3. Cosa il dato afferma, e quanto vale 2
4. Metriche del run (caso 1) 3
5. Cronologia dell’esposizione 4
6. Superficie di account 5
7. Identità e dati personali 5
8. Infrastruttura del dominio 6
9. Secondo caso: elon@nasa.com 6
10. Perché il secondo caso è istruttivo 7
11. Confronto tra i tre run 7
12. Terzo caso: elon.musk@hotmial.com 8
13. Gli undici indirizzi 9
14. Dati personali e credenziali esposte 9
15. Valutazione del rischio 11
16. Raccomandazioni 11
Appendice A — copertura 12
Appendice B — riproducibilità 12
Appendice C — confronto 13

1. Sintesi esecutiva

Il primo run — il caso e@x.com — ha raccolto 53 moduli su 78, con copertura dichiarata alta e un esito di rischio elevato. La parte solida del risultato è la **storia di esposizione**: l'indirizzo ricorre in dataset di breach molto noti, dal gaming cinese del 2011 a piattaforme di consumo e social fino al 2026. La parte fragile è la **ricostruzione dell'identità**, costruita per aggregazione automatica di segnali deboli su un dominio che appartiene a una società e non a una persona.

Dal punto di vista operativo il report va letto in due strati. Il primo strato è igienico: un indirizzo presente in 22 fonti di breach va considerato compromesso, le password riusate vanno cambiate e l'MFA va attivata ovunque. Il secondo strato è analitico: prima di attribuire il dato a una persona servono almeno due fonti indipendenti che non dipendano dalla stessa euristica, e in questo run non ci sono.

2. Avvertenza metodologica: dove il dato si rompe

Tre caratteristiche del run spiegano quasi tutti i risultati anomali. Vanno lette prima di qualsiasi conclusione.

Perché questo output va maneggiato con cautela

Local part di un carattere. Con "e" come parte locale, ogni pivot su username restituisce centinaia di corrispondenze quasi tutte casuali: il modulo *username_platforms* riporta 198 "hit", tutte marcate a bassa confidenza. Non sono account riconducibili alla casella.

Dominio aziendale, non personale. x.com è l'infrastruttura di X/Twitter. WHOIS, record DNS, certificati e snapshot Wayback descrivono il *dominio*, non il titolare della casella. I numeri di telefono WHOIS sono contatti di registrazione del dominio.

Attribuzione da fonte unica. "Elon Musk" è proposto con stato POSSIBLE sulla sola base del keyserver PGP, che associa il nome alla chiave pubblicata per quell'indirizzo: chiunque può pubblicare una chiave con qualsiasi nome. È una singola fonte, per giunta non verificata.

Somma di segnali eterogenei. Il punteggio di esposizione somma breach storici, snapshot di archivio del 1996 e commit GitHub del 2026. Sono fenomeni diversi: la loro somma produce un 100/100 che non distingue tra un breach del 2012 e un'esposizione di otto giorni fa.

3. Cosa il dato afferma, e quanto vale

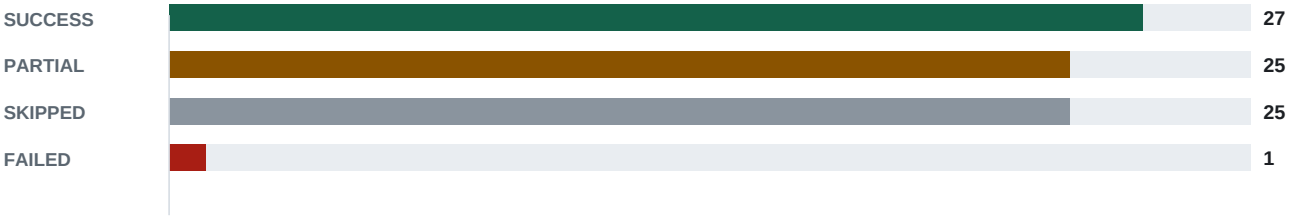
Affermazione nel run	Fonte / modulo	Valutazione
L'indirizzo è in 22 fonti di breach	XposedOrNot, LeakCheck	Solida sul piano della presenza, da confermare sul piano dell'effettiva appartenenza della casella.
Il nome è Elon Musk	pgp_keyserver (1 classe di fonte)	Non sostenibile. Fonte unica, controllabile da chiunque pubblica la chiave, nessun riscontro.
Il titolare usa l'handle *ierwinx*	github_commits, username_pivot	Non sostenibile. Le commit sono dell'autore del repository, non del titolare della casella; nessun legame provato con e@x.com.
Il dominio è attivo dal 1996	wayback, whois, dns	Vero ma riferito a x.com come dominio aziendale: non dice nulla sull'anzianità dell'indirizzo.
Esistono account su Adobe, Chess, Duolingo, GitHub	account_discovery, social	Plausibile ma a bassa confidenza: sono "segnali di registrazione", non accessi verificati.
Rischio credenziali 69 / ALTO	modello interno	Coerente con la storia di breach; da usare come indicatore relativo, non come misura.

Le voci marcate come non sostenibili restano nel report come traccia di lavoro, non come conclusioni. Nessuna azione deve essere intrapresa verso la persona suggerita.

4. Metriche del run (caso 1)

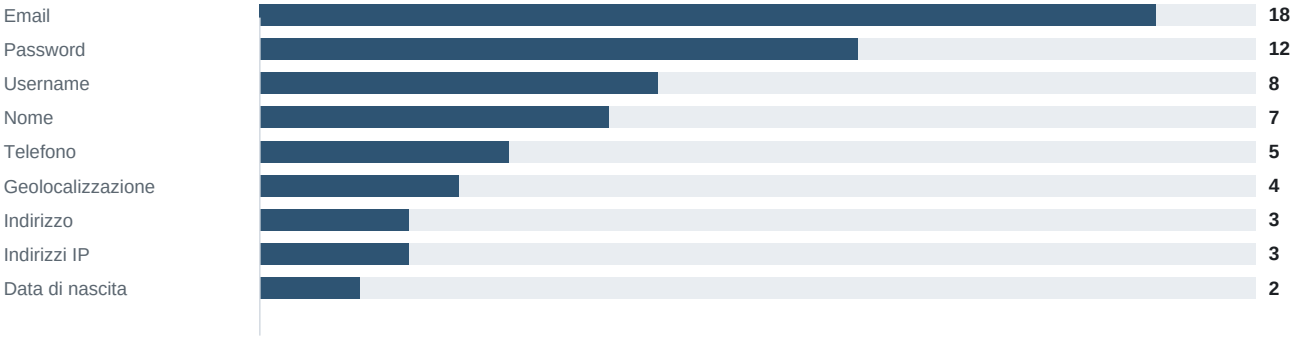
Indicatore	Valore	Lettura
Moduli eseguiti	53 / 78	27 SUCCESS, 25 PARTIAL, 1 FAILED; 25 saltati per chiavi o dipendenze mancanti.
Copertura dichiarata	ALTA	Alta sul piano delle fonti gratuite, incompleta sulle fonti a pagamento.
Punteggio di esposizione	100 / 100	Massimo raggiunto: indicatore saturo, non comparabile.
Rischio credenziali	69 (ALTO)	Ponderazione interna basata su volume e recenza delle esposizioni.
Fonti di breach	22	28 eventi includendo aggregati e voci collassate dal tool.
Paste / stealer	0 / 0	Nessun pastebin o log di stealer associato: riduce la probabilità di credenziali recenti in chiaro.
Account rilevati	15 segnali + 2 confermati	Segnali deboli di registrazione; Duolingo e Patreon risultano confermati.
Prima traccia	19/12/1996	Snapshot archivistico del dominio x.com.
Ultima evidenza	31/10/2026	Commit GitHub trovate per l'handle ipotizzato, non per l'email.

Esito dei moduli



Il blocco PARTIAL (25 moduli) è il più interessante: sono moduli che hanno restituito dati ma con timeout o risultati incompleti, spesso a 30 secondi esatti. Trattarli come prove parziali, non come assenza di evidenza.

Tipi di dato ricorrenti nelle fonti documentate



Numero di eventi, tra i 21 con dettaglio disponibile, in cui compare ciascun tipo di dato. Il telefono ricorre in cinque eventi: è il dato che pesa di più sul rischio di recupero account, più della password.

Perché conta la copertura

I moduli saltati includono le fonti più informative per questo tipo di analisi: HIBP, BreachDirectory, IntelX, Shodan, Netlas, Hunter, SerpAPI. La loro assenza spiega sia i 22 breach (invece dei 28 citati nel brief) sia l'assenza di verifiche indipendenti sull'identità. Il FAILED su *public_forge* (8,1 s) va inoltre investigato: un errore su un modulo di ricerca pubblica riduce la superficie osservata.

5. Cronologia dell’esposizione

Le date sono normalizzate dal tool al primo giorno dell’anno o del mese: servono a ordinare gli eventi, non a datare con precisione l’esposizione.

Anno	Fonte	Record	Dati esposti	Nota
2011	17173 e 7k7k (gaming, Cina)	7M + 7M	Email, username, password	
2012	Dropbox	69M	Email, password	
2012	Taobao	n.d.	Evento aggregato, dettagli non riportati	
2013	Adobe	152M	Email, username, password cifrate	Alto valore: riuso probabile
2013	iMesh	50M	Email, password, username, indirizzi IP	
2014	Banorte	2M	Telefono, indirizzo, email, sesso, nome, ID governativo	Dati sensibili
2015	NetEase (163.com)	233M	Email, password	
2015	Mate1	n.d.	Credenziali e dati di profilo	
2016	Anti Public Combo, Leet.cc, LBSG, uuu9	457M + 19M	Liste combinate di credenziali	Aggregati
2016	Adult FriendFinder	n.d.	Credenziali e dati di profilo	Dati intimi
2017	1.4BillionRecords (aggregato)	1,1 mld	Email, nomi	Aggregato
2017	MyHeritage	92M	Email, password	
2018	MyFitnessPal	144M	Email, username, password, IP	Alto valore
2019	Collection #1	791M	Email, password	Aggregato
2019	Verifications.io	763M	Email, nome, data di nascita, sesso, geo, telefono, indirizzo	PII estesa
2019	Zynga	173M	Email, username, password, telefono	
2020	Cit0day	227M	Email, password	Aggregato
2021	Twitter (200M)	209M	Username, email, nome, geo, foto profilo, telefono	Correlabile
2022	Twitter (scraping)	n.d.	Profili pubblici	Dati pubblici
2022	Payhere	2M	Email, telefono, nome, indirizzo	PII
2025	Under Armour	73M	Email, nome, sesso, geo, data di nascita	**RISCHIO ATTIVO**
2026	Chess.com	5M	Email, nome, username, geo	**RISCHIO ATTIVO**

Le due righe in rosso sono le uniche con finestra di rischio corrente. Le altre descrivono un’esposizione storica: contano per il riuso delle password e per la qualità dei dati di recupero account, non per un accesso immediato.

Come usare questa cronologia

Non leggere la tabella come 22 incidenti distinti: da un certo punto in poi gli stessi record circolano in più aggregati (Collection #1, Cit0day, 1.4BillionRecords), quindi il numero di eventi sovrastima l’esposizione reale. Il dato che conta è che una credenziale per questo indirizzo è circolata in chiaro almeno dal 2011 — e che due dataset recenti la collocano ancora su piattaforme attive.

6. Superficie di account

Il modulo *account_discovery* ha prodotto 15 segnali di registrazione. Sono indizi indiretti: indicano che l'indirizzo è stato usato su una piattaforma, non che l'account esista ancora o sia accessibile.

Piattaforma	Categoria	Confidenza
Babbel	lingue	segnale debole
Canva	grafica	segnale debole
Chess.com	gaming / competitivo	segnale debole
Disqus	commenti	segnale debole
ESPN	sport	segnale debole
MyFitnessPal	salute / fitness	segnale debole
Quizlet	studio	segnale debole
Stremio	streaming	segnale debole
Wix	siti web	segnale debole
Adobe	software / creatività	segnale debole
Duolingo	lingue	segnale debole
Office 365	produttività	segnale debole
Twitter / X	social	segnale debole
Vivino	vino	segnale debole
XVideos	adulti	segnale debole

Il brief operativo del tool cita 7 account confermati e nomina Adobe, Chess.com, Duolingo, GitHub e MyFitnessPal. Nel dettaglio dei moduli solo **Duolingo** e **Patreon** sono marcati come account trovati: la discrepanza va risolta prima di usare la lista.

7. Identità e dati personali

Elemento	Valore	Stato
Nome ipotizzato	Elon Musk	POSSIBLE, fonte unica (PGP)
Handle ipotizzato	ierwinx	non collegato all'email
Nome dal profilo GitHub	"Erwin" Distortion	profilo terzo, nessun nesso provato
Località dichiarata	México	dal profilo GitHub
Sito	ierwinx.com	dal profilo GitHub
Telefoni WHOIS	+48 62 425 …, +1 480 624 … (tre numeri)	contatti di registrazione del dominio

I tre numeri di telefono sono marcati a bassa confidenza dallo stesso tool e provengono dal WHOIS di x.com: sono contatti di registrazione del dominio, verosimilmente di un registrar o di un servizio di privacy, non del titolare della casella. Non vanno pubblicati né usati per contattare nessuno.

Perché l'identità resta un'ipotesi

Nessuna delle fonti che nominano una persona è indipendente dalle altre: il nome arriva dal keyserver PGP, l'handle da repository pubbliche che contengono l'indirizzo come stringa nel codice o nella configurazione git. Sono due catene diverse, ma entrambe partono dall'assunzione che l'indirizzo appartenga a chi lo ha scritto in un file pubblico: un'assunzione che regge per un indirizzo personale e non per un dominio condiviso.

8. Infrastruttura del dominio (caso 1)

Record	Valore	Lettura
A	172.66.0.227	Cloudflare: IP di fronting, non dell'organizzazione.
MX	Google Workspace	Posta gestita su Workspace: coerente con un dominio aziendale.
NS	b.u10.twtrdns.net	Nameserver di Twitter/X.
SPF	v=spf1 ip4:199.16.156.0/22 ...	Range storico di Twitter.
DKIM	record presente	Firma configurata.
DMARC	p=reject	Politica forte: spoofing del dominio mitigato.

Un DMARC in modalità reject significa che un'email con mittente forgiato su x.com viene scartata dai provider che applicano la policy: è un dato difensivo utile, ma non protegge da mittenti look-alike su domini diversi.

9. Secondo caso: elon@nasa.com

Il secondo run analizza un indirizzo dall'aspetto istituzionale e lo chiude con rischio BASSO, copertura BASSA e nessuna fonte di breach. Il punteggio di esposizione resta però 82/100: è il contrasto più utile per capire cosa misurano davvero questi numeri.

Indicatore	Valore	Lettura
Moduli eseguiti	52 / 78	26 saltati per chiavi o prerequisiti mancanti.
Errori	2	package_ecosystems (1,0 s) e public_forge (8,1 s).
Copertura dichiarata	BASSA	Nessuna fonte a pagamento attiva.
Punteggio di esposizione	82 / 100	Alto in assenza di breach: misura l'attività dei moduli.
Rischio credenziali	23 (BASSO)	Nessuna credenziale in dataset noti.
Fonti di breach	0	XposedOrNot e LeakCheck non restituiscono nulla.
Paste / stealer	0 / 0	Nessuna traccia.
Sottodomini raccolti	702	Da wordlist su un dominio parcheggiato.
Pivot su username	254 + 392	Corrispondenze lessicali su "elon" e "nasa".
Account	3 segnali + 1 confermato	Canva, Duolingo, Vivino; Patreon confermato.
Prima traccia	19/12/1996	www.nasa.com, "HOST Networks, Inc.".

Il paradosso dell'82/100

Un dominio senza un solo breach, senza paste e senza log di stealer totalizza 82 punti su 100, quasi quanto un indirizzo presente in 22 dataset. Il punteggio non sta misurando l'esposizione: sta misurando quanti moduli hanno restituito qualcosa. E su un dominio parcheggiato i moduli restituiscono molto, perché una wordlist applicata a un parcheggio produce comunque 702 righe.

10. Perché il secondo caso è istruttivo

Il dominio non appartiene all'organizzazione che il nome suggerisce. La NASA pubblica su nasa.gov. nasa.com è un dominio di terzi: i nameserver sono di ParkingCrew, un servizio che monetizza domini inutilizzati, il record A punta a un IP di parcheggio e lo snapshot del 1996 riporta "HOST Networks, Inc.". Un indirizzo elon@nasa.com non è quindi un indirizzo istituzionale: è una casella che, se esiste, sta su un dominio che non ha nulla a che vedere con l'agenzia.

Questo sposta il senso dell'intero run. Il tool cerca host, sottodomini e account per un dominio che non eroga servizi; il risultato sono 702 voci marcate come confermate, generate da una wordlist. La stessa logica produce 254 piattaforme per "elon" e 392 per "nasa": sono corrispondenze di stringa su nomi comunissimi, non account. Anche il nome "Elon Musk" ricompare identico al primo caso, dallo stesso keyserver PGP: la ripetizione non aggiunge evidenza, ripete lo stesso errore.

Segnali prodotti e valore probatorio

Segnale	Volume	Valore probatorio
Sottodomini (domain_harvester)	702	Nullo: wordlist su un dominio parcheggiato.
Pivot su username	254 + 392	Nullo: collisioni su nomi comuni.
Istanze fediverse	8	Nullo: /users/elon risponde per costruzione.
Segnali di registrazione	3	Debole.
Account social confermato	1 (Patreon)	Da verificare manualmente.
Keyserver PGP	1	Non probante: nome auto-dichiarato.
Fonti di breach	0	Informativo: nessuna esposizione.

11. Confronto tra i tre run

	1 · e@x.com	2 · elon@nasa.com	3 · elon.musk@hotmial.com
Dominio	x.com, di X/Twitter	nasa.com, parcheggiato	hotmial.com, typo di hotmail
Moduli eseguiti	53 / 78	52 / 78	4 / 16
Esposizione	100 / 100	82 / 100	4 / 100
Rischio credenziali	69 — ALTO	23 — BASSO	0 — BASSO
Fonti di breach	22	0	0
Paste / stealer	0 / 0	0 / 0	0 / 0
Pivot username	198 + 15	254 + 392	non eseguito
Identità proposta	PGP	PGP	local part
Esito	Esposizione reale	Rumore infrastrutturale	Nessun segnale

Guardati insieme, i tre run mostrano che il punteggio non ordina nulla: 100, 82 e 4 su tre indirizzi il cui rischio reale va nella direzione opposta (22 fonti di breach contro zero e zero). Tutto ciò che riguarda host, handle e nomi si genera allo stesso modo su un dominio attivo, su un parcheggio e su un dominio vuoto; quando non c'è nulla da raccogliere, il punteggio crolla a 4. L'unica variabile che distingue i casi è la storia di breach, letta insieme al rischio credenziali.

12. Terzo caso: elon.musk@hotmial.com

Il terzo run usa un profilo ridotto (16 moduli) e chiude con 4/100, rischio credenziali 0, nessuna fonte di breach e un avviso esplicito: provider usa-e-getta. È il caso di controllo che mancava ai primi due.

Indicatore	Valore	Lettura
Moduli eseguiti	4 / 16	Profilo ridotto: nessuna scansione del dominio.
Moduli saltati	12	Chiavi API e prerequisiti assenti.
Punteggio di esposizione	4 / 100	Quasi zero: nessun segnale raccolto.
Rischio credenziali	0 (BASSO)	Nessuna credenziale in dataset noti.
Fonti di breach	0	XposedOrNot non restituisce nulla.
Paste / stealer	0 / 0	Nessuna traccia.
Prima traccia	nessuna	Nessuna timeline: il dominio non produce archivio.
Classificazione	DISPOSABLE	Provider usa-e-getta secondo il tool.

Il modulo *email_credibility* restituisce però “high” mentre l’intestazione classifica il dominio come usa-e-getta: le due uscite non sono riconciliate e vanno verificate a mano prima di citare l’una o l’altra.

Il dominio è una trasposizione di hotmail.com

hotmial.com non è hotmail.com: le due lettere centrali sono invertite. hotmail.com è un dominio Microsoft; hotmial.com è un dominio diverso, di terzi. Il tool lo classifica come provider usa-e-getta, e in questo run non ha raccolto DNS, WHOIS né archivio — l’assenza di quei moduli è una lacuna da colmare, non una prova che il dominio sia innocuo. La conseguenza pratica è immediata: chi scrive a elon.musk@hotmial.com credendo di usare Hotmail consegna il messaggio a un estraneo, e chi risponde a quel mittente può parlare con un’altra persona.

Questo è il rischio vero del caso, e non ha nulla a che vedere con l’esposizione: un dominio che imita un provider noto è il veicolo tipico di phishing e di scambio di corrispondenza con il destinatario sbagliato. Va trattato come problema di integrità del canale, non come dato da ripulire.

L’identità viene dall’indirizzo stesso

Qui il nome non arriva dal keyserver: la fonte dichiarata è il local part, cioè la stringa “elon.musk”. Il tool la presenta come corroborante — “Email local-part corroborates” — ma è una corroborazione circolare: il nome è già contenuto nell’indirizzo che si sta analizzando, quindi la fonte non aggiunge nulla. È il grado zero dell’evidenza, e va trattato come tale: nessuna attribuzione.

> **Il caso di controllo che mancava**
>
> Con quattro moduli eseguiti e nessun segnale disponibile il punteggio crolla a 4/100. La pipeline quindi non è rotta in modo uniforme: risponde alla quantità di segnali che il dominio emette. È la prova che l’82/100 del secondo caso era rumore da parcheggio, e che il 100/100 del primo va letto solo attraverso le 22 fonti di breach.

13. Gli undici indirizzi: quadro d’insieme

Nove domini, quattro famiglie. x.com e tesla.com sono infrastrutture aziendali reali; nasa.com è un parcheggio; hotmial.com, gmial.com e gmial.ru sono trasposizioni di hotmail.com e gmail.com. La classificazione del rischio segue solo la prima famiglia.

Indirizzo	Dominio	Esp.	Cred.	Breach	Identità
e@x.com	x.com	**100**	69 ALTO	**22**	PGP
elon@tesla.com	tesla.com	**100**	69 ALTO	**11**	PGP + git
elonmusk@tesla.com	tesla.com	**100**	67 ALTO	**5**	PGP
elon@nasa.com	nasa.com	82	23 BASSO	0	PGP
Elusk@gmial.ru	gmial.ru	81	15 BASSO	0	nessuna
elon.musk@hotmial.com	hotmial.com	4	0 BASSO	0	local part
random9_9@gmial.com	gmial.com	2	0 BASSO	0	nessuna
itsmeelonemusk@gmial.com	gmial.com	2	0 BASSO	0	nessuna
korimusk@gmial.com	gmial.com	2	0 BASSO	0	nessuna
aenocutter@gmial.com	gmial.com	2	0 BASSO	0	nessuna
elonM@gmial.com	gmial.com	2	0 BASSO	0	nessuna

I due indirizzi su tesla.com sono caselle diverse sullo stesso dominio aziendale (Microsoft 365, DMARC in reject), entrambe attribuite a “Elon Musk” e entrambe presenti in log di infostealer. Se reali, appartengono a due persone diverse: la coincidenza del nome è l’unica cosa che le unisce.

14. Dati personali e credenziali esposte

Il run non ha trovato dati anagrafici: nessun indirizzo fisico, nessuna data di nascita, nessun documento. Ciò che esiste sono **contatti di registrazione dei domini** (WHOIS) e **appartenenza a dataset di breach**, con la relativa tipologia di dati. La tabella li riassume per indirizzo.

Indirizzo	Dati personali	Credenziali	Fonti
elon@tesla.com	3 contatti WHOIS del dominio (tel. +1 208 685 …, +1 415 531 …)	11 dataset, password in 7; stealer 2025 in chiaro	XposedOrNot, LeakCheck
e@x.com	3 contatti WHOIS del dominio (tel. +48 62 425 …, +1 480 624 …)	22 dataset, password in 12	XposedOrNot, LeakCheck
elonmusk@tesla.com	3 contatti WHOIS del dominio (gli stessi di elon@tesla.com)	5 dataset, password in 2; stealer 2025 in chiaro	XposedOrNot, LeakCheck
elon@nasa.com	2 contatti WHOIS del dominio (tel. +49 68 949 …, +1 954 607 …)	nessuna	—
Elusk@gmial.ru	inferenza “Elizabeth Lusk” da pivot su handle	nessuna	username_pivot
5 indirizzi @gmial.com	nessuno	nessuna	—
elon.musk@hotmial.com	nessuno	nessuna	—

Ultimi caratteri dei numeri oscurati: sono contatti di registrazione del dominio, non del titolare della casella. I valori completi restano nel log del tool.

Cosa c’è dentro i due run tesla.com

elon@tesla.com — 11 dataset: StarTribune (2019), Verifications.io (2019), JamesDelivery (2020), Flexbooker (2021), Payhere (2022), Naz.API (2023), Zacks (2024), Under Armour (2025), ALIEN TXTBASE (2025), RingCentral (2026), ZenBusiness (2026). Tre di questi — Payhere, Under Armour, Verifications.io — compaiono anche nel caso e@x.com: il totale di 38 segnalazioni sovrastima i dataset realmente distinti.

elonmusk@tesla.com — 5 dataset: Deezer (2019, 244 milioni di record con nomi, email e date di nascita), ALIEN TXTBASE (2025, 300 milioni, **password in chiaro**), Wired (2025, con telefono e indirizzo), Instagram (2026, con telefono e geolocalizzazione), Manchester Airports Group (2026, con IP, targa del veicolo e user agent).

Che tipo di dato è esposto, per categoria

Tipo di dato	Dove compare nel run	Fonte dichiarata dal tool
Nome ed email	tutti i dataset dei tre indirizzi con esposizione	XposedOrNot, LeakCheck
Password in chiaro	elon@tesla.com, elonmusk@tesla.com	ALIEN TXTBASE (2025)
Numero di telefono	elonmusk@tesla.com; contatti WHOIS di tesla.com e x.com	Wired (2025), Instagram (2026), WHOIS
Indirizzo fisico	elonmusk@tesla.com	Wired (2025)
Data di nascita	elonmusk@tesla.com (dataset da 244 milioni di record)	Deezer (2019)
Indirizzo IP e user agent	elonmusk@tesla.com	Manchester Airports Group (2026)
Targa del veicolo	elonmusk@tesla.com	Manchester Airports Group (2026)
Geolocalizzazione	elonmusk@tesla.com	Instagram (2026)
Dati di pagamento o documenti	nessun segnale nei run analizzati	—

La categoria di dato è quella che il tool attribuisce a ciascun dataset; non è stata verificata sul record, che il run non scarica.

Perché i contatti WHOIS non sono del titolare della casella

I contatti per dominio sono quelli registrati nel WHOIS e sono **gli stessi per ogni indirizzo sullo stesso dominio**: elon@tesla.com e elonmusk@tesla.com restituiscono i medesimi numeri. Una casella di posta non si registra: appartiene a un tenant. Il numero identifica quindi il dominio o il servizio che lo gestisce, non la persona che usa la casella. Attribuirlo al soggetto sarebbe lo stesso errore che il tool commette con il nome, e per questo i numeri sono abbreviati.

Non ci sono, invece:

- indirizzo fisico o documento d’identità riconducibile al titolare delle caselle;
- dati di pagamento: nessun dataset del run li contiene;
- password per e@x.com: il tool segnala la presenza del campo in 12 dataset, senza dire se in chiaro;
- alcun dato personale per i sei indirizzi su gmial.com e per hotmial.com: solo la conferma che il dominio è usa-e-getta.

Regola di trattamento

Questi dati riguardano indirizzi che non sono del committente: vanno usati per la remediation, non pubblicati, non aggregati in elenchi di contatto e non usati per scrivere agli indirizzi trovati. Le password non sono presenti nel report — solo l’indicazione che sono in chiaro nei log — e i numeri sono abbreviati.

15. Valutazione del rischio

Rischio	Prob.	Impatto	Prio.	Azione
Credential stuffing e riuso password sulle piattaforme elencate	Alta	Alto	**P1**	Password uniche, password manager, MFA.
Account takeover su Adobe, Dropbox, MyFitnessPal, Chess.com	Media	Alto	**P1**	Revoca sessioni, controllo email di recupero.
Phishing mirato costruito sui breach citati	Media	Alto	**P1**	Formazione, verifica del canale, filtro DMARC.
Doxing o attribuzione errata a una persona reale	Bassa	Medio	**P2**	Non pubblicare il nome; correggere il report.
Decisioni basate su falsi positivi (profilo, telefono)	Alta	Medio	**P0**	Congelare le conclusioni di identità.
Esposizione non misurata per moduli saltati	Certa	Medio	**P2**	Aggiungere chiavi API, rieseguire.
Indirizzo su dominio di terzi trattato come istituzionale (elon@nasa.com)	Alta	Basso	**P1**	Verificare il dominio prima del run: nasa.com non è nasa.gov.
Dominio che imita un provider noto (hotmial.com per hotmail.com)	Alta	Alto	**P1**	Segnalare al contatto: la posta arriva a un terzo.
Password in chiaro in log di infostealer (due indirizzi tesla.com)	Certa	Critico	**P0**	Rotazione immediata, revoca sessioni, MFA hardware.
Identità “confermata” da fonti non indipendenti (commit git + PGP)	Alta	Medio	**P0**	Riscrivere l’attribuzione: nessuna prova.

16. Raccomandazioni

P0 — prima di usare il report

Verificare che l’indirizzo sia reale. Un local part di un carattere su un dominio aziendale è il caso peggiore per gli algoritmi di pivot: genera 198 “account” e un’identità plausibile ma infondata. Se e@x.com è un artefatto di test, il report va etichettato come tale in copertina.

Congelare l’attribuzione. Non citare “Elon Musk” né l’handle *ierwinx* come identità del titolare. Servono due fonti indipendenti, non derivative dalla stessa euristica, e una verifica manuale.

Verificare il dominio prima dell’indirizzo. Se il dominio è parcheggiato o non appartiene all’organizzazione citata — nasa.com contro nasa.gov — l’indirizzo non esiste come casella istituzionale e il run va archiviato come test, non come indagine. Lo stesso controllo, su x.com, avrebbe evitato l’intera catena WHOIS e Wayback.

Leggere il dominio lettera per lettera. hotmial.com è hotmail.com con due lettere invertite: il tool lo rileva solo come “disposable”. Se un contatto usa quell’indirizzo al posto del proprio, ogni messaggio — comprese le credenziali inviate per errore — finisce a chi ha registrato il dominio.

Trattare come compromessi i due indirizzi su tesla.com. Le credenziali risultano in un log di infostealer con password in chiaro: non serve sapere se la casella appartenga davvero al soggetto indicato. Chi la controlla deve ruotare le password, revocare le sessioni e passare a fattori hardware, partendo da posta, recupero account e servizi finanziari.

P1 — se l’indirizzo è reale

- Attivare MFA su tutte le piattaforme con segnale di registrazione, in particolare Adobe, Dropbox, MyFitnessPal, Chess.com e Under Armour.
- Sostituire le password con credenziali uniche generate da un password manager; iniziare dalle caselle di posta e dai servizi di recupero.
- Revocare le sessioni attive e verificare le email e i telefoni di recupero: i dataset 2021 e 2022 contengono numeri di telefono.
- Controllare l’indirizzo su HIBP con k-anonymity e attivare le notifiche per le nuove esposizioni.
- Verificare l’integrità delle caselle collegate: una casella di recupero compromessa annulla l’MFA di tutti gli altri servizi.

P2 — qualità dell'analisi

- Aggiungere le chiavi per HIBP, BreachDirectory, IntelX, Shodan, Netlas e SerpAPI, e installare Playwright per il probe degli account: sono i moduli che oggi mancano.
- Indagare i due FAILED (*public_forge*, *package_ecosystems*) e i moduli PARTIAL con timeout a 30 s: la copertura reale è inferiore a quella dichiarata.
- Separare nel punteggio le esposizioni storiche da quelle degli ultimi 24 mesi, e non sommare eventi di dominio con eventi di casella.
- Aggiungere geolocalizzazione IP e, se serve la storia del dominio, un provider WHOIS storico.
- Pesare a zero, o escludere dal punteggio, i moduli che restituiscono volumi non verificabili (*domain_harvester*, *username_platforms*, *username_pivot*): 702 host e 646 pivot su un dominio parcheggiato non sono un risultato.

> **Regola di lettura**
>
> Undici indirizzi, punteggi da 2 a 100: i tre massimi hanno 22, 5 e 11 fonti di breach, ma due indirizzi con **zero** breach segnano 82 e 81. Il punteggio misura quanto rumore produce il dominio, non il rischio. Il valore del report sta nelle 38 segnalazioni di breach, nei due log di infostealer e nella lista di piattaforme da mettere in sicurezza.

Appendice A — Cosa non è stato eseguito

I tre run completi (x.com, tesla.com) hanno saltato 25–26 moduli su 78; i sei profili ridotti da 16 moduli ne hanno saltati 12 ciascuno, e il run su gmial.ru ha chiuso con quattro errori. La tabella riassume le cause e l'effetto sulla valutazione, perché un modulo saltato non equivale a un modulo negativo.

Causa	Moduli	Effetto sulla valutazione
Chiavi API assenti (HIBP, BreachDirectory, IntelX, Hunter, Shodan, Netlas, Companies House, SerpAPI)	12	Nessuna verifica indipendente dei breach e della superficie esposta.
Aggregatori non configurati e breach_deep disabilitato	8	Nessun accesso ai dataset completi: solo fonti gratuite.
Dipendenze mancanti (Playwright)	1	Nessun probe diretto dell'esistenza degli account.
Prerequisiti assenti (telefono, handle Twitter, profilo marketplace)	4	Moduli fuori contesto in questo run, non errori.
Errori di esecuzione (*public_forge*, *package_ecosystems*; su gmial.ru anche *pgp_domain_email* e *public_surface_sweeper*)	2–4	Forge, ecosistemi e PGP di dominio non completati.

Appendice B — Riproducibilità

```
mailaccess keys list
mailaccess investigate e@x.com -o report.html
mailaccess investigate elon@nasa.com -o report2.html
mailaccess investigate elon@tesla.com -o report_tesla.html
mailaccess investigate elon.musk@hotmial.com -o report_typo.html
mailaccess investigate random9_9@gmial.com -o report_gmial.html
# per la copertura completa:
export HIBP_API_KEY=... export INTELX_API_KEY=... export SHODAN_API_KEY=...
export ENABLE_BREACH_DEEP=true
```

Le variabili vanno impostate nell'ambiente della shell prima del run; le chiavi elencate sono quelle che il tool dichiara mancanti nell'output analizzato.

Appendice C — Confronto fra gli undici indirizzi

Gli indirizzi sono messi sullo stesso asse con le stesse colonne. Quelle numeriche sono dichiarate dal tool; la colonna **Pwd** conta i dataset in cui compare un campo password, non quante password esistono, e la colonna **Stealer** indica l'anno del log di infostealer in cui l'indirizzo è stato ritrovato.

Indirizzo	Dominio	Esp.	Cred.	Breach	Dataset	Pwd	Stealer
e@x.com	x.com	100	69 ALTO	22	22	12	—
elon@tesla.com	tesla.com	100	69 ALTO	11	11	7	2025
elonmusk@tesla.com	tesla.com	100	67 ALTO	5	5	2	2025
elon@nasa.com	nasa.com	82	23 BASSO	0	—	—	—
Elusk@gmial.ru	gmial.ru	81	15 BASSO	0	—	—	—
elon.musk@hotmial.com	hotmial.com	4	0 BASSO	0	—	—	—
random9_9@gmial.com	gmial.com	2	0 BASSO	0	—	—	—
itsmeelonemusk@gmial.com	gmial.com	2	0 BASSO	0	—	—	—
korimusk@gmial.com	gmial.com	2	0 BASSO	0	—	—	—
aenocutter@gmial.com	gmial.com	2	0 BASSO	0	—	—	—
elonM@gmial.com	gmial.com	2	0 BASSO	0	—	—	—

Totale: 38 segnalazioni di breach — 21 con campo password — 2 log di infostealer — 0 valori di credenziale riprodotti. Otto indirizzi su undici non espongono nulla: quello che li distingue è solo il dominio.

Dominio	N.	Segnali	Perché si comporta così
x.com	1	22 dataset, 12 con password	Infrastruttura di X/Twitter: il local part di un carattere genera 198 account; l'identità viene da un keyserver PGP, non dall'email.
tesla.com	2	16 segnalazioni, 9 con password, 2 stealer	Microsoft 365 con DMARC in reject. Le due caselle condividono WHOIS e nome: non è una prova che siano la stessa persona.
nasa.com	1	nessuno	Parcheggiato (NS parkingcrew): non appartiene alla NASA, che pubblica su nasa.gov. Il punteggio 82 nasce dall'infrastruttura, non da breach.
gmial.ru	1	nessuno, ma 408 host e 646 pivot	Parcheggiato (MX su blackhole). Harvester e username_pivot producono volume, non risultati.
hotmial.com	1	nessuno	hotmail.com con due lettere invertite: la posta arriva a chi ha registrato il dominio.
gmial.com	5	nessuno	gmail.com con due lettere invertite. Il run a 16 moduli si ferma al dominio e chiude con 2/100.

Perché i valori non ci sono

Il run riporta il nome del dataset e il fatto che contenga un campo password; non scarica e non stampa i record. Nessuna password compare quindi nell'output analizzato, e in questo report non ne viene ricostruita nessuna: sono credenziali di caselle che non appartengono al committente. Ciò che serve alla remediation è l'elenco dei servizi da mettere in sicurezza, non il valore della password.

Su una casella propria il controllo si fa in locale, con il log completo: password manager, verifica delle sessioni attive e delle email di recupero. Su una casella di terzi il massimo consentito è segnalare l'esposizione a chi la controlla.